

Proyecto

GAMMA



Visión Inicial de Calidad — Sistema de Expedientes Médicos

Hospital Gubernamental · Fase de Diseño · ISTQB CTFL v4.0 · ISO 27799

Cliente

Hospital gubernamental que necesita digitalizar su proceso de expedientes médicos.

Estado actual

Fase de diseño. Requerimientos definidos, pero sin cronograma de fases.

Problema humano

Médicos y enfermeras están en contra del proyecto. Resistencia al cambio activa.

Escrutinio público

La prensa cubre el proyecto. El estado evalúa los avances. Alta visibilidad.

ISTQB

CTFL v4.0 — 2023

Marco de referencia internacional
para clasificación y gestión de pruebas.

Aplica tipos de prueba: funcional,
no funcional, regresión y UAT.

Fuente: [istqb.org](https://www.istqb.org) (2023)

ISO 27799:2016

Seguridad de información en sector salud. Extiende ISO 27001/27002 con controles específicos para datos de pacientes.

ISO 27001:2022

Sistema de Gestión de Seguridad de la Información (SGSI). Base para implementar controles de ciberseguridad en el hospital.

Ley de Protección de Datos — Panamá

Ley 81 de 2019 y Decreto Ejecutivo 285/2021. Protección de datos personales aplicable a registros médicos.

OBJETIVO PRINCIPAL

Construir una plataforma que automatice y facilite el proceso de expedientes médicos del hospital, garantizando su calidad, seguridad y adopción por el personal.

OBJETIVOS ESPECÍFICOS

- Garantizar confiabilidad del sistema
- Validar usabilidad con médicos/enfermeras
- Verificar compatibilidad iOS y Android
- Documentar todo el proceso de QA
- Proteger datos de pacientes (ISO 27799)

ALCANCE Y MÉTRICAS

- M1 Registro — 100% campos validados
- M2 Actualización — cambios en <2s
- M3 Consulta — respuesta <3s en tablet
- M4 Reportes — sin errores estadísticos
- UAT — ≥80% tareas sin asistencia

RESTRICCIONES

- Sin dispositivo final definido
- Sin cronograma formal de fases
- Resistencia del personal médico
- Entregables de tercero sin validar
- Alta visibilidad pública y de prensa

1 Planificar

Creamos el cronograma de pruebas desde cero (la empresa anterior no lo hizo). Definimos criterios de entrada/salida para cada módulo.

2 Controlar

Monitoreo semanal: casos ejecutados vs. planificados, defectos abiertos/cerrados. Reportes ante el cliente y el estado.

3 Asegurar y mejorar

Walkthrough de los requerimientos heredados antes de probar. Mejora continua en cada sprint por los antecedentes problemáticos.

4 Políticas

- Política de confidencialidad de datos médicos
- Política de control de acceso por rol
- Política de manejo y escalamiento de defectos
- Política de comunicación con cliente y prensa

5 Procesos

Flujo: Detección → Registro en herramienta → Asignación → Corrección → Verificación → Cierre. Todo basado en los 4 módulos M1–M4.

6 Métricas

- % casos aprobados por módulo
- Densidad de defectos por KLOC
- Tiempo de respuesta en tablet (<3s)
- Tasa de aceptación del personal ≥80%
- Cobertura de pruebas ≥95%

7 Auditorías

Auditoría de herencia: revisión de entregables de la empresa anterior. Auditoría interna: trazabilidad completa. Auditoría externa: documentación lista para el estado.

ISTQB® CTFL v4.0

International Software Testing
Qualifications Board

- Certificación internacional más reconocida en QA
- Versión actual: CTFL 4.0 (mayo 2023)
- Clasifica pruebas en niveles y tipos
- Define métricas de proceso y cobertura
- Aplica a Waterfall, Agile y DevOps
- *Fuente: [istqb.org](https://www.istqb.org) — syllabus CTFL v4.0*

Nivel de prueba aplicado

Sistema/Integración — probamos módulos M1–M4 juntos e individualmente.

Tipos de prueba (CTFL)

Funcional, No-funcional (usabilidad, performance, seguridad), Regresión y Aceptación.

Técnica de diseño usada

Caja negra: Partición de equivalencia y BVA para campos del formulario de registro.

Métrica de cobertura

Cobertura de requisitos $\geq 95\%$. Densidad de defectos: defectos / KLOC del sistema.

~500–2,000

empleados

hospital 200–500 camas

35%

usan expedientes

médicos + enfermeras

3 roles

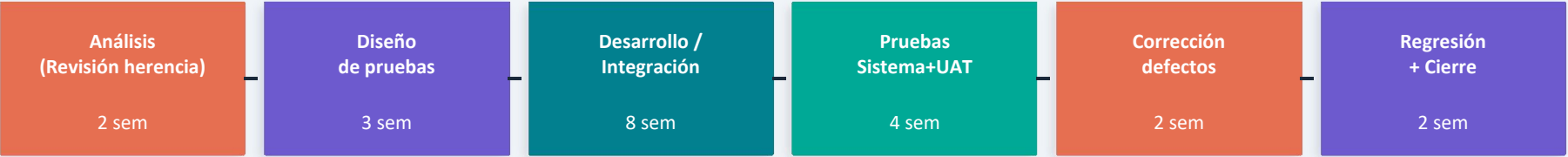
de usuario

médico, enfermera, admin

Jerarquía hospitalaria y usuarios del sistema

Cargo	Área / Rol	Proceso que realiza	Acceso
Director médico	Administrativo	Solo reportes	Lectura
Médico especialista	Clínico — USUARIO FINAL	Consulta y actualización	Lecto-escritura
Médico general/residente	Clínico — USUARIO FINAL	Registro y actualización	Lecto-escritura
Enfermera jefe	Clínico — USUARIO FINAL	Registro y signos vitales	Lecto-escritura
Enfermera / técnico	Clínico — USUARIO FINAL	Registro básico	Escritura
Admisiones / recepción	Administrativo — USUARIO FINAL	Registro inicial paciente	Escritura
Personal de TI	Soporte	Administración del sistema	Admin

Cronograma de fases — Total estimado: 21 semanas



Estimación de inversión del proyecto

Concepto	Detalle	Costo estimado
Base de datos (PostgreSQL + servidor)	Open-source. Servidor cloud: \$150–\$500/mes	~\$3,000–\$9,000/año
Especialista en ciberseguridad (ISO 27799)	1 consultor: \$3,000–\$8,000 implementación	\$3,000–\$8,000 único
Licencias de herramientas de prueba (Jira/TestRail)	Equipo de 5 personas	\$50–\$200/mes
Personal QA (testers) — fases de prueba	2–3 testers por 8 semanas de prueba	\$8,000–\$20,000
Capacitación y cambio organizacional	Sesiones de usabilidad con personal médico	\$2,000–\$5,000
TOTAL ESTIMADO PROYECTO		\$18,000–\$45,000 USD

¿Qué base de datos usar?

✓ PostgreSQL — RECOMENDADO para hospitales		
Criterio	PostgreSQL	MySQL
Soporte HIPAA/GDPR	✓ Nativo	Parcial
Integridad de datos	Excelente (ACID)	Buena
Escalabilidad	Alta	Media
Cifrado en reposo	✓ Nativo	Plugin
Open source	✓ Gratuito	✓ Gratuito
# 1 Stack Overflow 2026	✓ 12% crecimiento	—

Fuente: enterprisedb.com / tech-insider.org 2026

Criterio evaluado: Relación con la ley/normativa · Justificación técnica de la infraestructura

ISO 27799:2016 — Seguridad de datos médicos

 Confidencialidad

Solo personal autorizado accede a expedientes.

 Integridad

Los datos no se modifican sin trazabilidad.

 Disponibilidad

Sistema accesible 99.9% del tiempo en guardia.

 Control de acceso por rol

Médico, enfermera y admin tienen vistas distintas.

 Auditoría de accesos

Log de quién accedió a qué expediente y cuándo.

Fuente: pmg-ssi.com / encolaboracion.net — ISO 27799:2016

¿Qué preguntas contiene el formulario de expediente?

Datos de identificación

Nombre completo

N° de cédula / ID

Fecha de nacimiento

Género

Nacionalidad

Dirección

Teléfono / contacto de emergencia

Datos médicos iniciales

Tipo de sangre

Alergias conocidas

Enfermedades crónicas

Medicamentos actuales

Antecedentes familiares

Vacunas aplicadas

Cirugías previas

Datos de la visita / atención

Motivo de consulta (síntoma principal)

Fecha y hora de ingreso

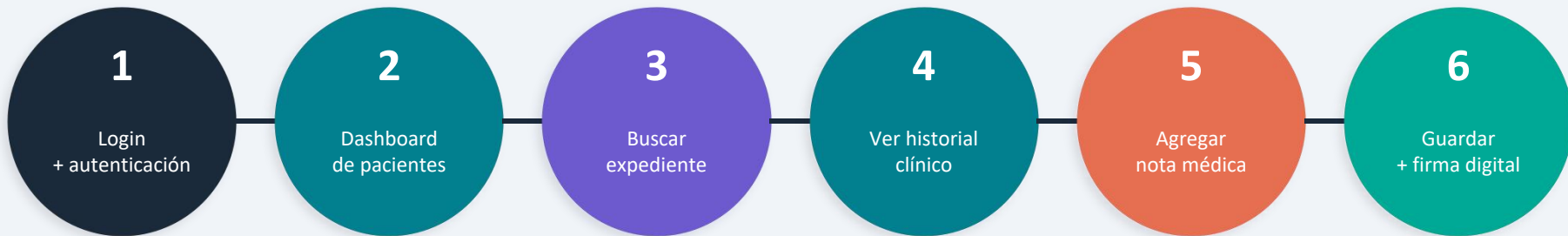
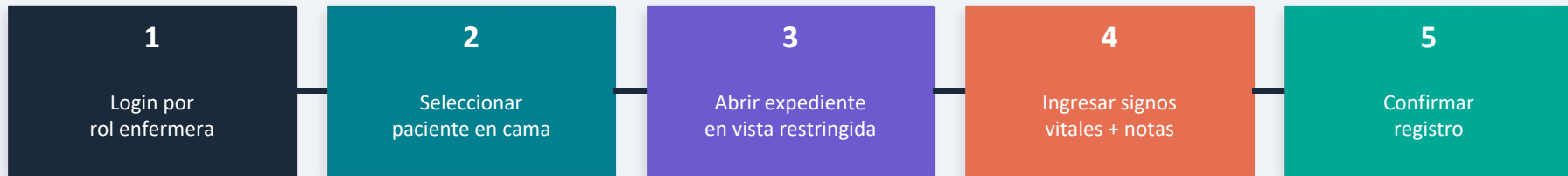
Médico tratante asignado

Área / especialidad

Signos vitales (presión, temp, O2)

Diagnóstico preliminar

Plan de tratamiento

Flujo: Médico — Consulta y actualización de expediente**Flujo: Enfermera — Registro de signos vitales**

Cada rol ve solo las funciones permitidas. El médico tiene acceso completo; la enfermera solo registra. El admin solo genera reportes.

⚠ Un sistema médico que falla puede costar vidas — el plan de contingencia es un requisito de calidad crítico, no opcional.

Nivel 1 Degradación

Cuándo: Tiempo de respuesta >5s o error en módulo individual

Acción: Modo lectura. Sistema de papelería de emergencia activado (formularios físicos).

Nivel 2 Fallo parcial

Cuándo: Caída de 1–2 módulos o pérdida de conexión de BD

Acción: Failover automático al servidor de respaldo (PostgreSQL réplica). Notificación a TI en <5 min.

Nivel 3 Fallo total

Cuándo: Caída completa del sistema o brecha de seguridad

Acción: Activar protocolo ISO 27799: congelar accesos, notificar a dirección del hospital, iniciar restauración desde backup diario.

Funcionales

Módulos M1–M4

Verificar que M1–M4 funcionen según requerimientos definidos.

Compatibilidad

iOS y Android

Sin dispositivo final definido → probar en iOS y Android obligatoriamente.

Rendimiento

Performance

Tabla EMR con miles de registros → tiempo de consulta <3s garantizado.

Usabilidad

Resistencia personal

Personal médico está en contra → pruebas con usuarios reales reducen resistencia.

Seguridad (ISO 27799)

Datos médicos

Datos sensibles de pacientes → control de acceso, cifrado y auditoría de logs.

Aceptación UAT

UAT doble capa

Dos capas: formal con el hospital + usuarios reales (médicos y enfermeras).

M1

Registro

100% de campos obligatorios validados sin errores. Datos recuperables en <1s.

M2

Actualización

Cambios reflejados en <2s. Historial completo sin pérdida de datos. Log de cambios activo.

M3

Consulta

Tiempo de respuesta <3s en tablet. Búsqueda devuelve expediente correcto al 100%.

M4

Reportes

Informes generados con datos completos, sin errores estadísticos, en <10s para 100 registros.

UAT con personal médico: ≥80% de tareas sin asistencia · Aceptación formal del hospital: ≥95% módulos aprobados · Seguridad: 0 vulnerabilidades críticas

Criterio evaluado: Argumentación sólida de criterios de aceptación

Lo que nos diferencia

- 01 Cada prueba justificada directamente desde el contexto del caso (ISTQB CTFL v4.0).
- 02 La resistencia del personal médico es gestionada como riesgo de QA, con UAT como herramienta de cambio.
- 03 ISO 27799:2016 + PostgreSQL = infraestructura de datos médicos segura y conforme.
- 04 Plan de contingencia de 3 niveles garantiza operación continua del sistema hospitalario.
- 05 Las 7 componentes de gestión de calidad estructuran cada decisión técnica del equipo.